GITHUB.COM/POOJAKIRA/MCP-AGENT-SECURITY-GATEWAY · EXPERIMENTAL PR #167 AGAINST MAIN

Runtime Policy Enforcement at the AI Agent-to-Tool Boundary

Validated MCP/JSON-RPC Development Gateway · Integration CI, November 2026

Evidence status: Development integration candidate, NOT a production release. Python CI results are from PR #167's synthetic merge commit 2ab3380d1457cdcb16c3ba143db9d8e339b057e2, GitHub Actions run 42748742036 (2026-11-10 UTC). Source-implementation branch head was 25bc77445df5fa5fdcdff64478b0f63079dbb8ca. Results must not be generalized to deployments, new commits or external traffic.

1,158
Tests passed
Python 3.12, reviewed PR merge commit

6
Tests skipped
Python 3.12 CI; 0 failed

83.10%
Statement coverage
Linux Python 3.12, not detector accuracy

7,327
Statements measured
1,238 missed; same CI job

69
Prompt-injection signatures
Source inventory; not population recall

9
Elastic Security rules
detection_rules/elastic_rules.toml

21
Core SIEM tests
tests/test_siem.py

7
SIEM scenario tests
tests/test_siem_scenarios.py; corrected from 12

Contribution

A bounded agent-to-tool inspection and authorization gateway combining JSON-RPC framing checks, capability and policy decisions, normalization and heuristic detection, hash-chained audit records, and selected protected MCP execution adapters.

Problem & Threat Model

- LLM agents can transform malicious or untrusted content into structured calls with filesystem, process, or network consequences.
- Tool arguments and results may carry prompt injection, exfiltration instructions, spoofed identity claims, or ambiguous JSON-RPC frames.
- Only requests forced through a supported gateway or separately protected downstream adapter are within the enforcement boundary.

Method

1. Parse JSON-RPC and reject malformed input and ambiguous duplicate keys in tested paths.
2. Normalize selected Unicode and encoded content before heuristic injection checks.
3. Evaluate server trust, identity/capability and tool-specific policy.
4. Block disallowed actions before forwarding where the supported adapter enforces this.
5. Record decision, correlated audit information, and bounded side-effect/revocation evidence.

Current Verified Evidence

- 1,158 passed, 6 skipped, Python 3.12 CI, 0 failed at reviewed PR merge commit.
- 83.10% statement coverage on Linux/Python 3.12: 7,327 statements, 1,238 missed.
- Python 3.10 / 3.11 also each passed 1,158 tests and skipped 6; statement coverage was 83.13% / 83.10% respectively.
- Focused identity, effect journal, retired-key, revocation and protected-MCP regression suite: 42 passed on Python 3.12.
- Real disposable filesystem MCP smoke workflow: 1 passed. This does not establish a non-bypassable production deployment.

Integration Validation

- Source inventory: 69 named prompt-injection regex signatures; a count, not precision, recall or guaranteed bypass prevention.
- Elastic Security inventory: 9 [[rule]] records; core SIEM module: 21 test_* functions.
- SIEM scenario runner: 7 test_* functions, verified in source and the November pytest log. Earlier poster text incorrectly listed 12.
- CI included lint, typing, CodeQL, build, security hygiene, targeted AppSec, local lab configuration, real MCP smoke and poster parity; every check has its own scope.
- The poster source is not evidence of external SOC adoption, incident prevention, live egress containment, or response-time improvement.

Reproducibility

PR #167, CI run 42748742036, Python 3.12.16, synthetic merge 2ab3380d; see reproducibility companion for exact commands and evidence boundaries.

Honest Boundaries

- PRODUCTION NO-GO: controlled integration tests and green workflows do not meet the release acceptance requirements.
- Direct access to a tool server can bypass a gateway that is not enforced by the actual deployment.
- Production principal binding, broad MCP protocol/transport interoperability and authentic network destination fencing are not independently established.
- SQLite-coordinated revocation and effect logging are local proofs, not distributed exactly-once execution or rollback.
- Heuristic prompt-injection detection has unknown representative false-positive and false-negative rates; no independent blind benchmark is claimed.

Release Decision

- Research prototype / draft integration candidate. Do not merge or deploy on the strength of test counts.
- Release authority remains the security review and its open mandatory gates, including external identity, restricted outbound networking, crash recovery, full protocol compatibility, independent red teaming and human approval.
- The earlier October 14 poster snapshot of 782 passed / 81.93% remains historical and is not mixed with this November CI measurement.

Evidence Sources & References

- GitHub Actions full CI run 42748742036, Python 3.10/3.11/3.12.
- Integration security checks run 42748741925; real MCP smoke run 42748742254.
- src/mcp_monitor/detectors/prompt_injection.py.
- detection_rules/elastic_rules.toml.
- tests/test_siem.py and tests/test_siem_scenarios.py.
- docs/review/PHASE13_RELEASE_READINESS.md, release decision NO-GO.